

ISMS Scope Statement — CyroPay Ltd ISO/IEC 27001:2022 Gap Assessment

Date: May 2026

CyroPay Ltd is a fictional organisation created for portfolio purposes. No real client data was used.

CyroPay Ltd's Information Security Management System (ISMS) covers the people, processes, and technology used to design, develop, operate, and support its UK-based digital payment platform and associated services provided to merchants. The ISMS applies to the information assets processed, stored, or transmitted in delivering these services, and to the internal systems and workflows required to operate and secure them.

In scope

- CyroPay's payment application, customer-facing and internal APIs, and supporting services
- Production and non-production environments
- Customer and merchant information assets (including personal data and transaction-related metadata)
- Tokenized payment references returned by a PCI DSS-compliant payment processor
- Cloud infrastructure and security services hosted on Amazon Web Services (AWS)
- Internal corporate systems used to build, operate, and support the service (e.g., identity and access management, endpoint management, change management, ticketing/support workflows, monitoring/logging)
- London head office environment
- Approved remote working arrangements for employees and contractors (including the devices and access methods used to connect to CyroPay systems)

Out of scope

- Storage, processing, or transmission of cardholder data (CHD) (e.g., PAN, CVV2) on CyroPay-managed systems, as payment card processing is performed by a PCI DSS-compliant third-party payment processor and CyroPay retains only tokens and non-sensitive transaction data required for operations and reconciliation
- Planned physical branch locations not yet operational
- Systems and networks owned and operated solely by any parent or affiliated organisations where CyroPay has no operational control

- Consumer personal devices and non-CyroPay-managed IT assets, unless explicitly authorised for business use under CyroPay's remote working and endpoint security requirements
- Third-party services beyond the extent to which they are used to deliver or support in-scope services and are governed through CyroPay's supplier risk management and contractual controls

Interested parties

- Financial Conduct Authority (FCA)
- Information Commissioner's Office (ICO)
- Acquiring banks and payment partners
- Merchant customers and business partners
- Cardholders/data subjects whose personal data may be processed by CyroPay (not CHD)
- The PCI DSS-compliant payment processor (as a critical supplier)
- Key technology/service suppliers supporting delivery of the platform (e.g., AWS and other critical SaaS/service providers)
- CyroPay employees and contractors

Payment processing assumption

CyroPay uses a PCI DSS-compliant payment processor (e.g., Stripe) with a hosted payment page / hosted fields implementation, so cardholder data (PAN/CVV2) is entered directly into the processor's environment. CyroPay systems do not store, process, or transmit CHD and retain only tokens and non-sensitive transaction metadata for reconciliation, refunds, chargebacks, and reporting.